Федеральное государственное автономное
образовательное учреждение высшего образования «Национальный
исследовательский университет ИТМО»

Дисциплина: Информационная безопасность

Работа 1: Разработка защищённого REST API с интеграцией в CI/CD

Выполнил:
Кара-Огланов Руслан Денисович
Группа: P3407

Санкт-Петербург
2026

Содержание:

Цель и разработка API: 3

Реализованные меры защиты: 3

Тестирование и CI/CD: 4

Результаты проверок: 5

Вывод: 5

Цель и разработка API:

Цель работы — разработать REST API с аутентификацией и автоматизированной проверкой безопасности. Использованы Java 17, Spring Boot, Spring Security, Maven, Spring Data JPA и H2. Реализованы вход пользователя, получение и создание записей.

POST /auth/login принимает JSON с полями username и password. После успешной проверки возвращается JWT в поле token. GET /api/data возвращает записи из H2. POST /api/data принимает title и content и сохраняет запись с именем автора. Для двух методов /api/data необходим заголовок Authorization: Bearer <токен>.

Реализованные меры защиты:

SQL-инъекции: сохранение и получение записей выполняются через JpaRepository и Hibernate без конкатенации SQL с вводом пользователя. XSS: при формировании JSON-ответа title, content и createdBy экранируются функцией HtmlUtils.htmlEscape. Это кодирование для HTML-текста; клиент также должен безопасно отображать ответ.

Аутентификация: Spring Security проверяет пароль с помощью BCrypt. JWT подписывается секретным ключом; фильтр проверяет подпись и срок действия и устанавливает пользователя в контекст безопасности. Запрос без аутентификации отклоняется со статусом 401. Приложение работает без серверной сессии. Пустые поля отклоняются Bean Validation со статусом 400.

Учебная конфигурация содержит демонстрационного пользователя и общий список записей. Перед эксплуатацией необходимо вынести секрет подписи и учётные данные в переменные окружения и определить правила доступа к записям.

Тестирование и CI/CD:

Автоматические тесты проверяют запуск контекста, успешный вход и выдачу JWT, отказ без токена, доступ с токеном, создание записи, отклонение пустых полей и экранирование HTML. Локально выполнено 7 тестов без ошибок.

GitHub Actions запускает три независимые задачи: API tests, SpotBugs с FindSecBugs и OWASP Dependency-Check. Отчёты сохраняются как artifacts. В ходе статического анализа выявлены жёстко заданное значение пароля и глобальное отключение CSRF; конфигурация изменена, после чего проверка прошла. Перенос хэша в properties сам по себе не заменяет безопасное хранение конфигурации.

Репозиторий: https://github.com/selfishinside/secure-rest-api

Проверенный успешный запуск: https://github.com/selfishinside/secure-rest-api/actions/runs/42838025696

Результаты проверок:

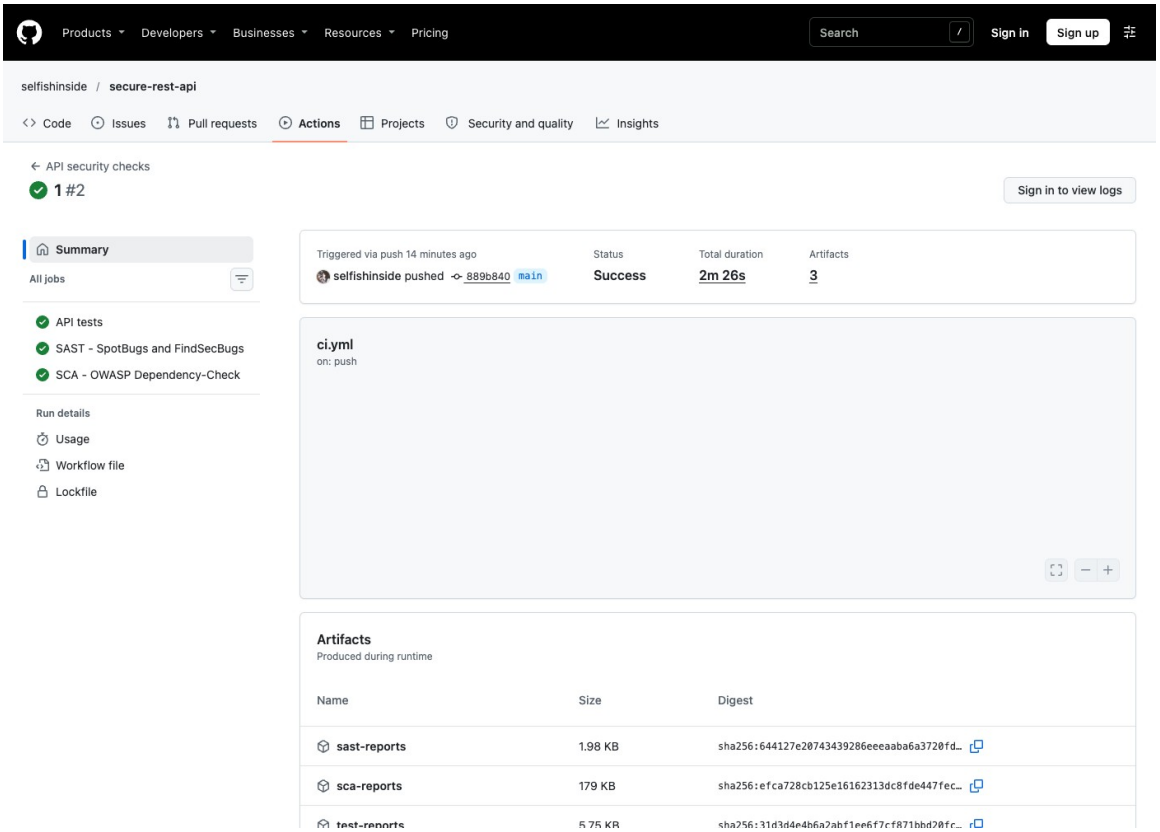


Рисунок 1. Результаты запуска GitHub Actions

SAST: https://github.com/selfishinside/secure-rest-api/actions/runs/42838025696/job/129905352067

SCA: https://github.com/selfishinside/secure-rest-api/actions/runs/42838025696/job/129905352787

Вывод:

Разработано API с хранением данных в H2, JWT-аутентификацией, BCrypt и проверкой входных данных. Запросы к базе выполняются через ORM, а HTML-символы экранируются при выдаче данных. Автоматические тесты и проверки SAST/SCA включены в CI. Успешный pipeline подтверждает выполнение настроенных проверок, но не гарантирует отсутствие всех уязвимостей.